

MAFSN ICT — Configuration TO-DO

Joget configuration tasks owned by the MAFSN ICT team

Lesotho Farmers Portal — implementation team

2026-05-06

Table of Contents

MAFSN ICT — Configuration TO-DO

Audience: MAFSN ICT team running the Lesotho Farmers Portal in production. **Purpose:** A list of configuration tasks that MAFSN owns directly — nothing here requires us to write code or rebuild a plugin. All items are done through Joget’s standard configuration surfaces (App Composer, user management, plugin properties). **Estimated total effort:** 2–3 days of focused configuration + 1–2 weeks elapsed for the security-review item which depends on an external auditor.

The four items below are sequenced in recommended order — items 1 and 2 should ideally be in place before opening the system to real citizens or real operators; items 3 and 4 are ongoing process disciplines.

1. Citizen notifications (SMS + email gateway integration)

The portal currently tracks every voucher state change but doesn’t proactively tell the farmer. Citizens learn that their voucher has been issued by going to the centre and asking. SMS notification fixes this.

What to send

Trigger	Channel	Recipient	Message
Application submitted	SMS + email	Applicant	“Your application AP-XXXXXX has been submitted. We will SMS you when the review is complete.”
Application auto-approved	SMS	Applicant	“Your application is approved. Voucher VCH-... is valid until DD-MM-YYYY at .”
Application rejected	SMS	Applicant	“Your application could not be

			approved. Reason: . Please contact your local extension officer.”
Voucher 7 days from expiry	SMS	Applicant	“Your voucher VCH-... expires on DD-MM-YYYY. Please collect at .”
Voucher redeemed	SMS	Applicant	“You have collected at . Thank you.”

Email is optional; SMS is the primary channel because mobile network coverage (~85% of Lesotho population) significantly exceeds smartphone penetration.

How to wire it (Joget configuration, no code)

The portal already exposes the lifecycle hooks; you just need to attach notification tools to them.

For email: Joget DX 8 ships with the **Email Tool** plugin (org.joget.apps.app.lib.EmailTool). To use it:

1. App Composer → Generic > Email Tool — configure SMTP host / port / username / password / from-address.
2. App Composer → APIs → Tool Plugin — wire Email Tool to the appropriate process step or form post-processor:
 - On subsidyApplication2025 form’s postProcessor (after submit)
 - On subsidyApplicationOperator2025 form’s postProcessor (after operator decision)
 - On the existing voucher / redemption / expiry process tool steps.

For each, set: - to = #form.subsidy_app_2025.email_address# (or #form.farmerBasicInfo.email_address# for registry-resolved address) - subject = templated string (use Joget’s hash-variable syntax) - body = templated message body

For SMS: Joget Marketplace has plugins for several gateways. For Lesotho:

- **Vodacom Lesotho Bulk SMS** — they expose an HTTP POST endpoint; use Joget’s **REST Tool** (built-in) to wire it. You’ll need a Vodacom Bulk SMS account first.
- **Africa’s Talking** — a regional aggregator with Lesotho coverage. Africa’s Talking ships a Joget plugin (search “Africa’s Talking” in Joget Marketplace).
- **Twilio** — international-grade, plugin available, more expensive.

Whichever gateway, the wiring shape is the same: a tool plugin attached to the same lifecycle hooks listed above. Use #form.field_name# to substitute farmer name, voucher code, etc.

Costs to budget for: SMS in Lesotho is roughly LSL 0.30–0.50 per message at bulk rates. At 50,000 farmers × 3 SMS each per cycle, budget roughly LSL 60,000–80,000 per cycle. Email is effectively free.

Decision required from MAFSN: which SMS gateway, and what’s the budget allocation. Once decided, configuration is one Joget-admin day.

2. Role-Based Access Control (RBAC) enforcement

Today every logged-in user sees every menu in the userview. In production, MAFSN should restrict what each role can do. This is configuration only — Joget supports it natively.

Step 2a — Define groups

Joget calls them “Groups”. Open Settings → Setup Users → Groups → New. Recommended group taxonomy (matches the role model in `_design/architecture/components/im-module-roles.md`):

Group ID	Name	What they need access to
programme_manager	Programme Manager	Programme design (mm_registration), determinant authoring, allocation plans
operator_inbox	Operator (Application Reviewer)	MOA Office category, operator inbox, application detail, decision form
warehouse_manager	Warehouse Manager	Inputs Management → Inventory + Stock Transactions; can see Suppliers (read)
counter_staff	Counter Operator (Distribution Agent)	Inputs Management → Redeem Voucher, Distribution Receipts
finance_lead	Finance Lead	Budget category in full + GL Export + manual adjustments
me_lead	M&E Lead	Reports category + read-only on most other surfaces
analyst	Analyst (Configuration)	MM - Configuration category (mm_screen, mm_field, etc.); read-only on operational data
sysadmin	Sysadmin	Admin category; full access for emergencies
citizen	Citizen	Registration Forms

category only (the public wizard)

(Joget supports user-to-multiple-groups membership, so a person who is both Programme Manager and Finance Lead joins both groups.)

Step 2b — Apply per-menu permissions

The 8 userview categories have ~ 140 menus today. Edit `_userviews/v.json` or use App Composer's Userview Builder, and on each menu set the **Permission** property to the appropriate group.

Recommended mapping (group → categories visible):

Category	Visible to
Registration Forms	citizen, operator_inbox, sysadmin
MOA Office	operator_inbox, programme_manager, sysadmin
Budget	finance_lead, programme_manager, me_lead (read-only menus only), sysadmin
Inputs Management	warehouse_manager, counter_staff, programme_manager, sysadmin
Reports	me_lead, programme_manager, finance_lead, sysadmin
MM - Configuration	analyst, sysadmin
Admin	sysadmin only
Master Data	analyst, sysadmin

(Within each category, individual menus may need finer grain — e.g. in Inputs Management, the Redeem Voucher HtmlPage is for counter_staff + warehouse_manager only, while the audit log is for me_lead and sysadmin.)

Step 2c — Enforce on API endpoints

API Builder lets you scope each API definition to an authenticated user or service account, not just the shared key. For the production deployment:

- The citizen wizard's API can stay on the shared key (citizens are anonymous by design).
- The operator decision API and budget dispatch APIs should be tied to named service accounts whose membership in operator_inbox / finance_lead is checked at request time.
- The MDM list endpoint can stay open (it returns reference data, not PII).

Step 2d — Real users, demo users out

The current dev environment has 12 demo users (admin, clark, julia, etc.) and 3 demo groups. For production:

1. Disable / delete the demo accounts.
2. Create real MAFSN staff accounts. Either through Joget's user management UI, or via LDAP/AD integration if MAFSN already runs an identity provider.
3. Assign each user to their groups.

Recommended: start with 5–10 named staff per role, expand as operations scale.

Estimated effort for items 2a–2d: half a day for the configuration, plus the time it takes MAFSN HR/IT to confirm the staff list.

3. External security review

Before opening the portal to real citizens at scale, MAFSN should commission an external security review. This is procurement on your side; we cannot do it ourselves.

What to ask the auditor for

A typical OWASP-aligned web application security assessment, with agriculture-sector + PII scope add-ons:

1. **OWASP Top-10 review** of the citizen wizard and the operator surfaces. SQL injection (we believe we're protected by Joget's DAO + JdbcDataListBinder's parameterised queries; auditor confirms), XSS (Joget escapes by default; HtmlPage menus require care), CSRF (Joget tokens by default), broken authentication, etc.
2. **API security review** — every endpoint enabled in API Builder. Rate limiting, abuse detection, authorisation depth. Confirm no endpoint allows arbitrary table reads or schema introspection.
3. **PII handling** — the farmer registry contains national IDs, household composition, GPS coordinates. Confirm encryption at rest (Postgres TDE or filesystem encryption), encryption in transit (HTTPS/TLS 1.2+), access-log retention discipline, data-deletion request handling (right-to-be-forgotten under any applicable law).
4. **Joget version + plugin CVE check** — the running Joget DX version plus all custom plugins (reg-bb-engine, form-creator-api, joget-smart-search, etc.). Auditor checks each against published CVE databases.
5. **Backup encryption + key custody** — who holds the keys, where are they kept, what's the rotation policy.
6. **Incident response** — what happens if a breach is suspected. Logging discipline, log retention, who gets notified.

Recommended providers

A regional shortlist (we don't endorse any specifically; consult MAFSN procurement):

- Lesotho-based: ?
- South Africa-based: SecureData (Johannesburg), MWR InfoSecurity ZA, KPMG South Africa Cyber Practice.
- Internationally available remotely: NCC Group, Bishop Fox, Trail of Bits.

Budget: typical OWASP-Top-10 assessment of a single-app system runs USD 15k–40k depending on depth and provider. Allow 2–3 weeks elapsed once the auditor is engaged.

What to do with findings

The auditor returns a report with severity-ranked findings. For each:

- **Critical / High** — must fix before production exposure. We help with the code-side fixes; you pay for the audit re-test.
- **Medium** — fix within 30 days of report.
- **Low / Informational** — backlog; address opportunistically.

4. Production hardening checklist

Operational discipline that MAFSN ICT owns. Most items are hosting-side, not Joget-config.

4a — JVM heap + Tomcat tuning

The Joget JVM in dev runs on default heap (likely 1–2 GB). For production with 50K farmers + heavy reporting:

- Heap: at least 4 GB (-Xmx4g), 8 GB if budget allows.
- Tune G1GC: -XX:+UseG1GC -XX:MaxGCPauseMillis=200.
- Confirm -Xss (per-thread stack) is sane: -Xss256k.
- File descriptor ulimit: at least 65536.

Edit /etc/systemd/system/joget.service (or wherever the unit file lives) and restart Joget after changes. Verify with `jcmd <pid> VM.flags` after restart.

4b — Postgres connection pool

The default Joget connection pool config is small. For production load:

- Edit wflow/wflow-postgres/META-INF/wflow.properties:
 - wflowDataSource.maxIdle=20 (default 5)
 - wflowDataSource.maxActive=80 (default 20)
 - wflowDataSource.maxWait=30000 (30s)
- Postgres-side: max_connections should be at least 200 (default often 100 on managed Azure tiers — request an increase if needed).
- Confirm Postgres shared_buffers is at least 25% of available RAM.

4c — Log rotation + retention

Joget logs to wflow/joget.log and grows unbounded. Set up logrotate:

```
# /etc/logrotate.d/joget
/path/to/wflow/joget.log {
    daily
    rotate 30
    compress
    delaycompress
    missingok
    notifempty
    copytruncate
}
```

Retention: 30 days is typical for operational logs; the `reg_bb_eval_audit` table has its own playbook (see CLAUDE.md “Audit retention” section) — that’s separate from infrastructure logs.

4d — Backups

- **Postgres:** Azure-managed snapshots cover this — verify the schedule is daily and retention is at least 30 days. The next item delivers a tested restore procedure.
- **JWA + plugin .jar files:** tracked in git (`gs-plugins/` directory). Verify the repo has off-site mirror (GitHub / GitLab / Bitbucket).
- **wflow/app_formuploads/** (signature PNGs, invoice scans): this is on the VM disk. Add to a daily rsync/snapshot to a separate storage account.

4e — Monitoring

- **Application logs** — already handled by 4c.
- **System metrics** — install `node_exporter` and Prometheus (or use Azure Monitor’s VM agent). Track: CPU, memory, disk I/O, JVM heap, Tomcat thread count.
- **Application metrics** — Joget doesn’t expose Prometheus natively. As a low-effort proxy: a daily cron job that runs the e2e test (`_tooling/test_im_e2e.py`) and alerts if it fails.
- **Postgres metrics** — Azure Postgres surfaces these in the portal; add alerts on connection-pool exhaustion and disk-space warnings.

4f — TLS / HTTPS

Production must be HTTPS only. If you’re terminating TLS at an Azure App Gateway / nginx in front of Tomcat:

- Disable Tomcat’s HTTP connector entirely (or bind it to localhost only).
- Configure HSTS headers: Strict-Transport-Security: max-age=31536000.
- Disable TLS 1.0 and 1.1; enforce TLS 1.2 minimum.
- Use Let’s Encrypt or an Azure-managed cert; rotate quarterly.

4g — DNS + branding

- Confirm `farmersportal.gov.ls` (or chosen DNS name) points at the production VM.
- Configure the userview’s logo to the MAFSN crest (App Composer → Userview → Theme → Logo).

- Confirm citizen-facing screens display “Ministry of Agriculture, Food Security and Nutrition” as the brand owner.

Summary — What MAFSN owns vs what we own

Item

1. Citizen SMS / email notifications
 2. RBAC group + permission setup
 3. External security review
 4. Production hardening
- Code fixes from security findings
- Backup/restore runbook (tested)
- Performance/load test results
- Donor-grade financial reporting

Once items 1, 2, and 4 are in place and item 3 has cleared, the system is ready for production exposure. Item 3 is the long pole — start the procurement now if you haven’t already.

Authored: 2026-05-06. Revise after each operational cycle to reflect what was actually done and what’s still outstanding.